

【제 목】 : 보건의료 빅데이터 분석 공간 및 이용자PC 보안 관리 마춤(시정 권고)

【내 용】

○ 빅데이터실은 「공공데이터 제공 및 이용 활성화에 관한 법률」 제26조(공공데이터 제공)에 따라 우리 원이 보유한 공공데이터를 국민이 활용할 수 있도록 제공하고 있고,

- 우리 원 빅데이터를 분석할 수 있는 공간인 보건의료빅데이터 분석센터 및 보건의료빅데이터스타디움(이하 “분석 공간”이라 한다)을 제공·운영하고 있다.

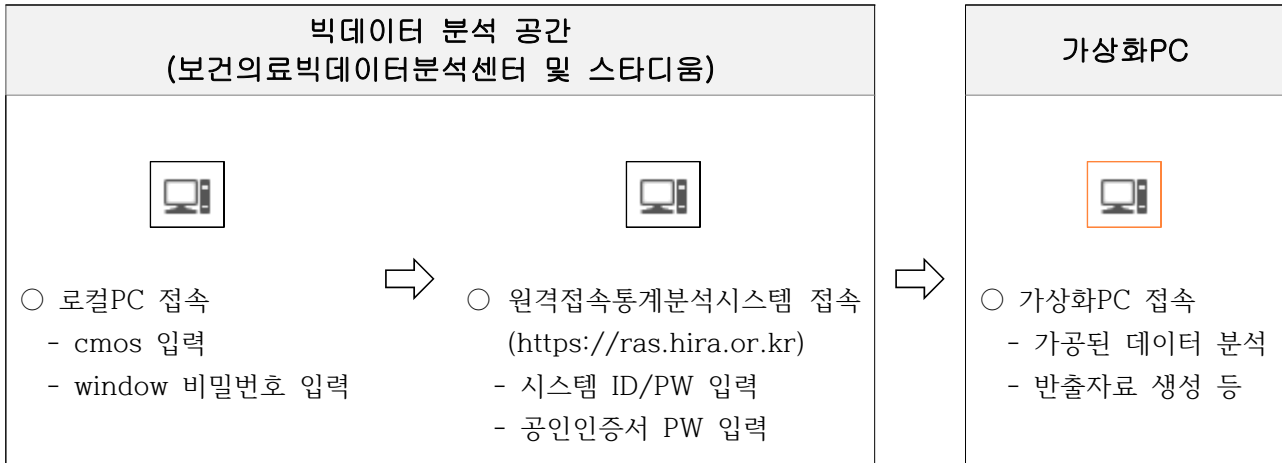
☞ 참고자료: 【우리 원 운영 빅데이터 분석 공간】

구분	보건의료빅데이터분석센터 (총 95석)												
	본원		서울		부산	대구	광주	대전	수원	창원	의정부	전주	인천
	청구	영상	송파	서초									
좌석	15	20	13	29	2	2	2	2	2	2	2	2	2

가. 이용자PC 보안에 관한 사항

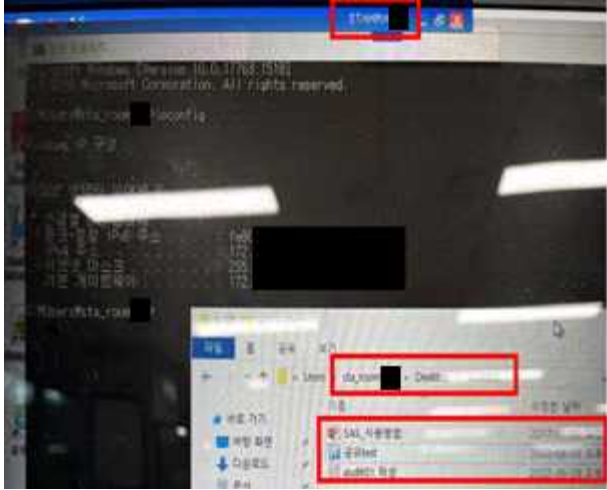
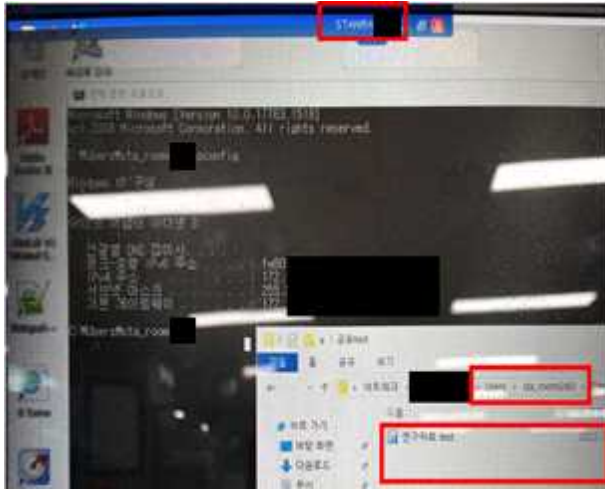
- 빅데이터실은 분석 공간의 보안강화를 위해 사전 승인 받은 이용자만 출입할 수 있도록 하고, 해당 이용자가 출입 시 출입 관리대장, 보안유지 및 준수사항 서약서를 작성하게 한 후 배정된 좌석의 로컬PC와 가상화PC에서만 이용가능하게 하고 있다.
- 이용자는 배정된 로컬PC를 통하여 원격접속통계분석시스템을 가상화PC로 접속한 후 가명처리 등 가공된 데이터를 분석하는 등의 작업을 수행하고 있다.

☞ 참고자료: 【분석 공간 내 로컬PC 및 가상화PC 접속 절차】



- 한편, 우리 원 「정보보안 지침」 제73조(단말기 보안) 및 제75조(비밀번호 관리)에 따르면 PC 내의 업무상 불필요한 프로그램 설치 금지 및 공유 폴더를 삭제하고, CMOS·로그온 비밀번호의 정기적 변경 및 동일한 비밀번호를 여러 사람이 공유하여 사용하지 못하도록 되어 있다.
- 이에 감사 대상기간 동안 분석 공간의 로컬 및 가상화PC를 점검한 결과,
 - 【표 1】과 같이 PC간 파일 및 폴더의 공유가 가능한을 확인하였으며, 이 경우 이용자들끼리 자료를 주고받을 수 있어 이용자가 이용 목적 외의 정보를 수집할 가능성이 있고, 가명 처리된 자료라 하더라도 서로 다른 다량의 자료가 합쳐질 경우 가명적용 패턴 등이 유출될 가능성이 존재하며,

【표 1】 파일 및 폴더 공유 확인

sta_room280	sta_room402
	
○ sta_room000계정에서 sta_room000계정이 공유한 폴더 및 파일에 접근 가능	○ sta_room000계정에서 sta_room000계정이 공유한 폴더 및 파일에 접근 가능

- 보건의료빅데이터센터의 경우 로컬 및 가상화PC 접속 비밀번호가 【표 2】와 같이 비밀번호 마지막 자리에 PC 관리순번을 부여하여 타 이용자의 PC 접속 비밀번호를 유추가능하게 되어 있어, PC 비밀번호의 보안관리가 미흡한 것을 확인하였다.

【표 2】 통계분석DB 테이블 현황

PC번호	로컬PC		가상화PC		공인인증서 비밀번호
	cmos	windows	아이디	비밀번호	
⋮	⋮	◇◇◇◇1!	⋮	⋮	⋮
3	☆☆☆#03	◇◇◇◇1!	★★★0003	◎◎◎03	◎◎◎03
4	☆☆☆#04	◇◇◇◇1!	★★★0004	◎◎◎04	◎◎◎04
⋮	⋮	◇◇◇◇1!	⋮	⋮	⋮

- 따라서 분석 공간 내의 로컬 및 가상화PC 간의 파일 및 폴더공유를 차단하여 이용자의 목적 외로 활용될 수 없도록 하고,
- 보건의료빅데이터센터의 로컬 및 가상화PC의 비밀번호를 유추할 수 없도록 하고 주기적으로 변경하는 등 PC보안 관리를 강화할 필요가 있다.

나. 출입 보안 관리에 관한 사항

- 「보건의료빅데이터분석센터 운영 기준」의 보안 관리에 따르면 보건의료빅데이터센터 및 스타디움의 출입 시 통제할 수 있는 물리적 보안, 출입하는 이용자 등에 대한 관리적 보안, 분석시스템 접근 권한 부여 등 기술적 보안을 거친 후 이용할 수 있도록 관리·운영하고 있고,
 - 분석 공간 내의 출입 및 작업 통제를 위해 관리자가 상주하여 확인하는 것을 원칙으로 하고, 관리자는 감시카메라(CCTV) 모니터링, 출입 관리대장 확인 등의 업무를 통하여 보안 관리를 수행하고 있다.
- 이에 감사 대상기간 동안 분석 공간의 출입 보안을 확인한 결과, 보건의료빅데이터센터는 주말 및 공휴일 등 이용시간이 아닌 경우 출입을 통제하고 있으나,
 - 실증랩이 있는 보건의료빅데이터스타디움은 이용자(의사)가 평일 이용시간에는 환자 진료 등으로 방문하기 어려운 경우 「보건의료빅데이터분석센터 운영 기준」에 따라 상주 관리자가 부재중인 휴무일에 출입하여 작업할 수 있도록 사전신청을 받은 후 승인하고 있으며, 출입증은 휴무일전 평일에 센터 관리자로부터 제공 및 반납하고 있다.
 - 그러나 이용자가 휴무일 작업 시 출입문을 상시 개방하고 있는 사례를 확인하였고, 출입증 1개로 여러 사람이 출입 가능한 구조로 인해 승인받지 않은 사람이 추가로 출입이 가능하거나, 출입증을 승인받지 않은 타인에게 주어 출입이 가능할 수 있음을 확인하였다.

- 따라서 보건의료빅데이터스타디움에 휴무일 등 관리자의 부재 시 이용자가 출입하는 경우,
 - 출입자에게 휴무일 이용에 따른 주의사항과 위반에 따른 책임 사항을 보안 서약서에 추가 및 교육조치 하고,
 - 출입문 상시개방이 불가하도록 조치를 하는 등 보안을 강화할 필요가 있다.

【관계부서 의견】

- 분석 공간에서 이용되는 로컬 및 가상화PC의 보안강화가 필요함을 느꼈고, 빅데이터스타디움의 경우 이용자가 휴무일에 이용 시 출입문의 보안강화를 위해 관련부서와 협의하여 보완 조치할 수 있는 방안을 마련하겠다는 의견을 제시하였다.

【조치할 사항】

- 기획상임이사는

- ① 분석 공간의 로컬 및 가상화PC에서 파일 및 폴더가 공유되지 않도록 조치하시고, 각 PC의 접속비밀번호를 유추할 수 없도록 변경 및 주기적으로 변경하여 PC보안 관련 업무를 철저히 하시기 바라며, (시정)
- ② 보건의료빅데이터스타디움에 이용자가 휴무일 등 출입 시 보안을 강화할 수 있는 방안을 마련하시기 바랍니다. (권고)